UT3

IMPLANTACIÓN DE MEDIDAS DE SEGURIDAD PERIMETRAL

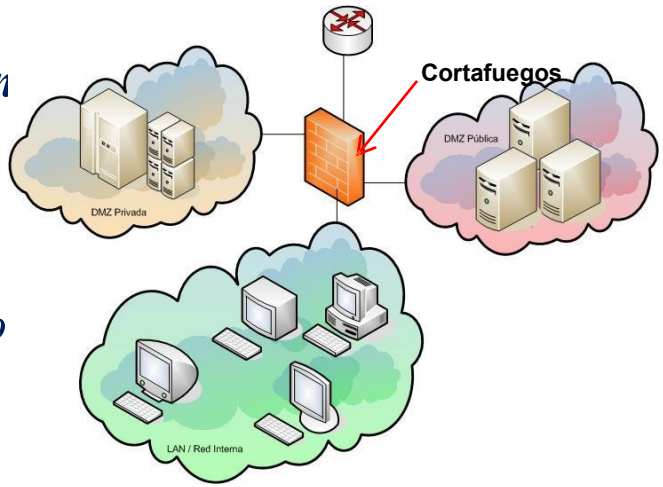
SEGURIDAD PERIMETRAL

INTRODUCCIÓN

- Cuando una red corporativa se encuentra **interconectada a una red pública**, los peligros de ataque a sus servidores, encaminadores y sistemas internos se multiplican.

- Todas las líneas actuales de investigación en seguridad de redes comparten una **idea**:

  *"la concentración de la seguridad **en un punto**, **obligando** a todo el **tráfico entrante y saliente** a que pase por ese mismo punto, que normalmente se conoce como **cortafuegos o firewall**, permitiendo concentrar todos los esfuerzos en el control de tráfico a su paso por dicho punto".*

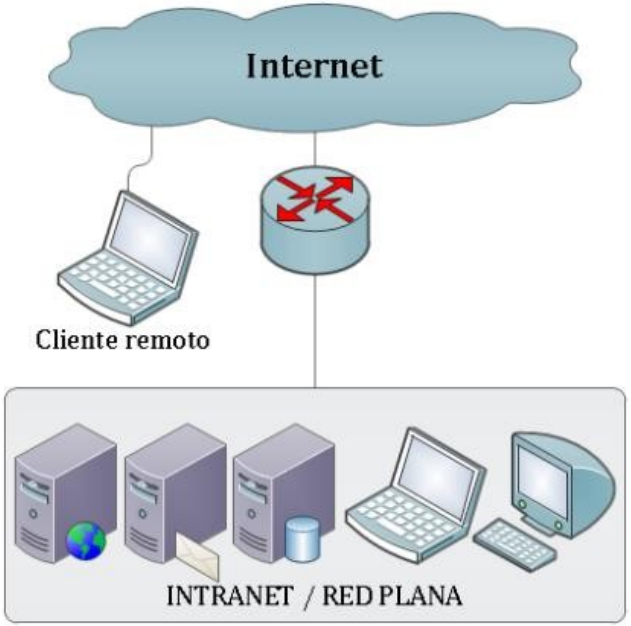


SEGURIDAD PERIMETRAL

SEGURIDAD PERIMETRAL

INTRODUCCIÓN

- Ejemplo de Arquitectura sin **Seguridad Perimetral**
  - Red plana sin segmentar
  - Publicación de servicios internos
  - No hay elementos de monitorización
  - No se filtra tráfico de entrada ni de salida
  - Cliente remoto accede directamente a los servicios.



SEGURIDAD PERIMETRAL

INTRODUCCIÓN

- Concepto de **Seguridad Perimetral**
  - Podremos considerar la **Seguridad Perimetral** como la ***primera línea de defensa*** entre las redes públicas y privadas.
  - La seguridad perimetral implementa diferentes tipos de arquitectura Para proteger nuestra "red interna" o "subred protegida".

    Pueden encontrarse en cualquier punto entre estos dos extremos:
    - **Débil de "subred protegida"**. Configuración sencilla y poca protección.
    - **Fuerte de "subred protegida"**. Configuración compleja y alta protección.

SEGURIDAD PERIMETRAL

INTRODUCCIÓN

- Concepto de **Seguridad Perimetral**
  - Podremos considerar la **Seguridad Perimetral** como la ***primera línea de defensa*** entre las redes públicas y privadas.

- Tipos de **medidas** de seguridad perimetral:



  - **Cortafuegos** o *firewalls*
    - Destinados a **bloquear** las conexiones no autorizadas.
  - **Proxies**
    - Aplicaciones que hacen de **intermediario** entre clientes y servidores finales, permitiendo el filtrado y monitorización de servicios.



INTRODUCCIÓN

- Tipos de **medidas** de seguridad perimetral (cont.):
  - **Red Privada Virtual (VPN)**
    - Tecnología que permite extender **de forma segura** una red local sobre una red pública.
    - Permite a los miembros de la organización trabajar de forma remota accediendo a los mismos recursos que si estuviesen en local.



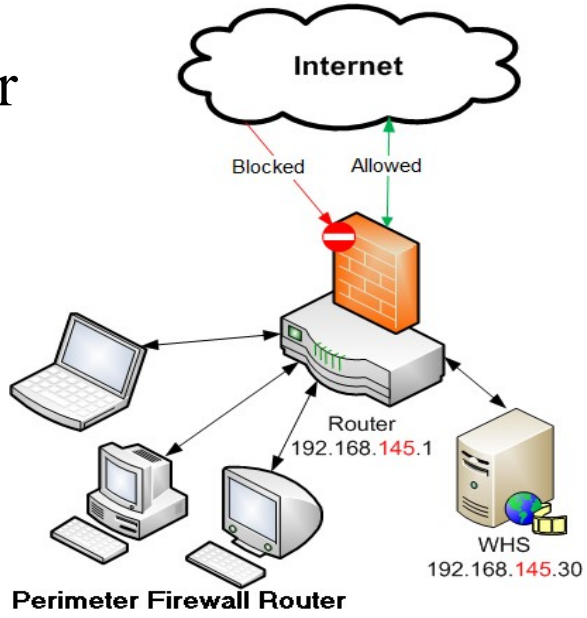
    - Requiere:
      - Controlar el acceso de los usuarios desde el exterior.
      - Confidencialidad. La información que viaja por la red debe estar encriptada (algoritmos de cifrado DES, 3DES, AES).
      - Integridad. Los datos enviados no son alterados, se usan funciones hash (MD5, SHA1, SHA2, SHA3).

SEGURIDAD PERIMETRAL

1. CORTAFUEGOS

- Un **cortafuegos** consiste en un dispositivo o aplicación
  - formado por uno o varios equipos que se sitúan entre la red de la empresa y la red exterior (*normalmente Internet*),
  - que **analiza todos los paquetes que transitan entre ambas redes**,
  - y **filtra** los que no deben ser reenviados, de acuerdo con un **criterio establecido de antemano**, de forma simple.

- La **configuración** para permitir y limitar el tráfico entre diferentes redes o ámbitos de una red se realiza en base a un conjunto de **normas** y **reglas**.



SEGURIDAD PERIMETRAL

1. CORTAFUEGOS

- El cortafuegos crea un **perímetro** de seguridad y defensa de la organización que protege.

- Al definir un perímetro, el cortafuegos opera también como **NAT** (*Network Address Traslation*) y **Proxy** (*servidor multipasarela*).

- Permite proteger determinadas zonas de nuestra red o determinados hosts de:
  - Amenazas provenientes del **exterior**.
  - Amenazas que se provoquen dentro de **nuestra propia red** ya sean por infecciones o ataques.

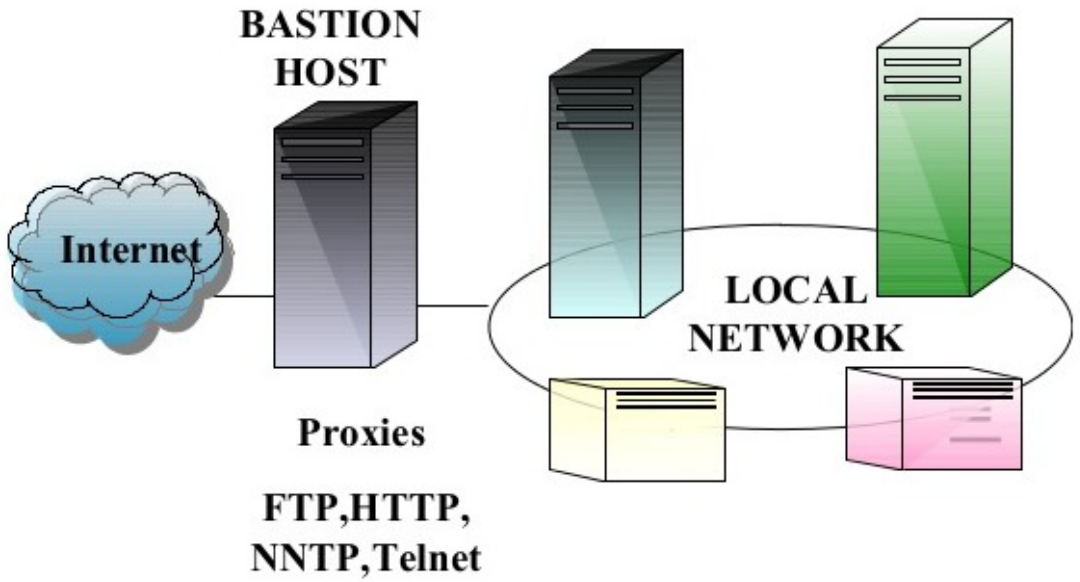
SEGURIDAD PERIMETRAL

1. CORTAFUEGOS

- Trabajo a nivel de circuito.
  - Establece un circuito entre origen y destino de la comunicación actuando a nivel de transporte.
  - El circuito sólo se establece si las aplicaciones y puntos de origen y conexión de la comunicación están autorizados (supervisa números de secuencia de paquetes).
- Actuar como **sistema bastión**. Un sistema bastión es un:
  - Sistema especialmente asegurado.
  - Expuesto a ataques.
  - Punto de contacto entre usuarios de red interna y externa.

1. CORTAFUEGOS

- Las **funciones** de un **sistema bastión** son:
  - Filtrado de tráfico.
  - Ocultar la configuración interna de la red.



1. CORTAFUEGOS

- Las características fundamentales de los cortafuegos son:
  - **Filtrado de paquetes de red** en función de la inspección de direcciones de red: *IP* o *puerto origen* y *destino*, permitiendo con este último criterio un filtrado según las aplicaciones asociadas a dicho puerto. También puede filtrar por direcciones físicas (*MAC*).
  - **Filtrado por aplicación**: permite especificar las aplicaciones y reglas específicas para cada una de ellas.
  - **Reglas de filtrado sobre el tráfico** de salida o de entrada en un determinado *interfaz* de red.
  - **Registro o *logs*** de filtrado de paquetes.

SEGURIDAD PERIMETRAL

1. CORTAFUEGOS

- Existen diversos cortafuegos en Windows. Algunos de ellos son:

Comodo Firewall https://personalfirewall.comodo.com/

ZoneAlarm http://www.zonealarm.com/

Avs Firewall http://www.avs4you.com/index.aspx

Kerio Control https://www.gfi.com/es/products-and-solutions/network-security-solutions/keriocontrol

Windows Defender

Mejores Firewall 2023

1. CORTAFUEGOS

- En Linux el cortafuegos por excelencia es

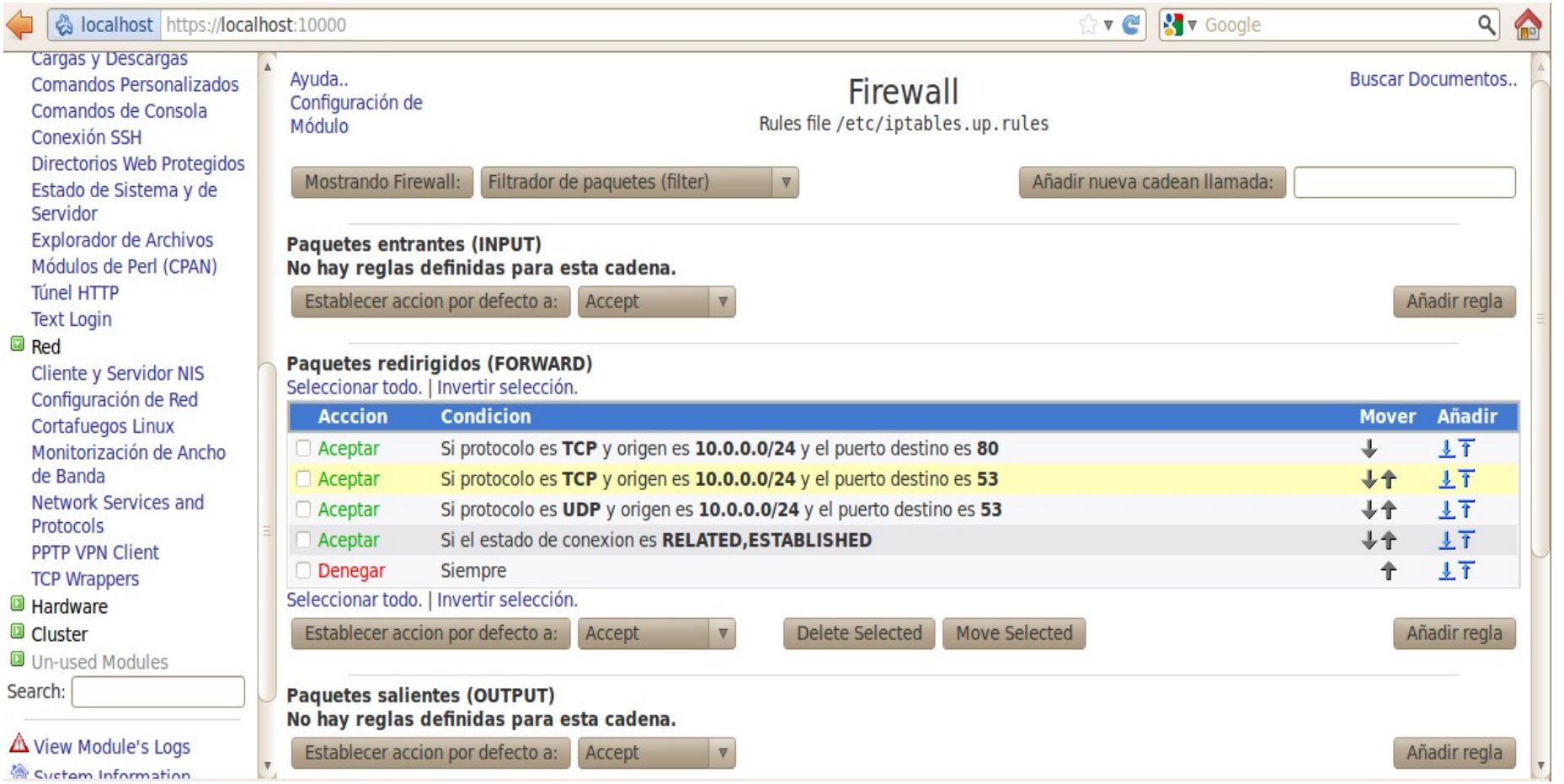
  iptables

- Pero también existen interfaces gráficas de configuración de un cortafuegos en Linux:

Gufw	https://help.ubuntu.com/community/Gufw
Dwall	http://dag.wieers.com/home-made/dwall/
FireHOL	http://firehol.sourceforge.net/
Firewall Builder	https://www.kali.org/tools/fwbuilder/
Shorewall	http://shorewall.org/
Webmin	http://www.webmin.com

SEGURIDAD PERIMETRAL

1. CORTAFUEGOS



Iptables con Webmin

1.1. TIPOS DE CORTAFUEGOS

- Una clasificación posible de un cortafuegos es por la **ubicación** en la que se encuentre:
  - **Cortafuegos basados en servidores**: aplicación de *firewall* que se instala y ejecuta en un sistema operativo de red, que normalmente ofrece otra serie de servicios como enrutamiento, proxy, DNS, DHCP, etc.





  - **Cortafuegos dedicados**: son *equipos* que tienen instalado una aplicación específica de cortafuegos y, por tanto, trabajan de forma autónoma como cortafuegos.

1.1. TIPOS DE CORTAFUEGOS (cont.)

- **Cortafuegos integrados**: se integran en un dispositivo hardware para ofrecer la funcionalidad de *firewall*. Como ejemplos, encontramos *switches* o *routers* que integran funciones de cortafuegos.





  - Los routers filtran a nivel de puerto y dirección IP. Por ejemplo: se puede permitir navegar en la WWW (puerto 80), descargar ficheros ftp (puerto 21) y denegar las conexiones por telnet (puerto 23). También trabajan a nivel de transporte y red. No realizan filtrado a Nivel de aplicación (simplemente determinan si un paquete pasa o no).

1.1. TIPOS DE CORTAFUEGOS (cont.)

- **Cortafuegos personales**: se instalan en los distintos equipos de la red de forma que los proteja *individualmente* de amenazas externas. Por ejemplo, en un equipo doméstico, el cortafuegos preinstalado en un sistema operativo Windows. Nivel de protección básico.

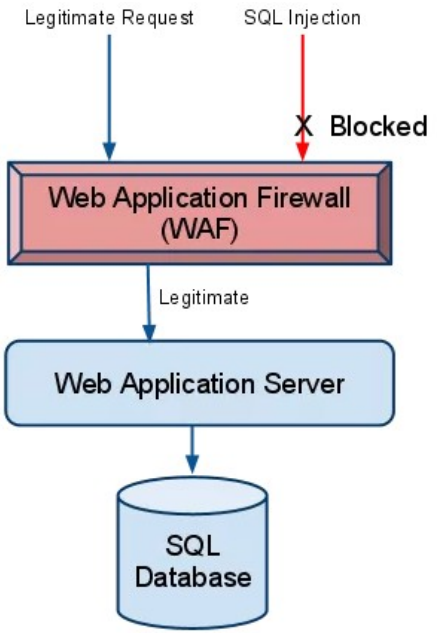




1.1. TIPOS DE CORTAFUEGOS (cont.)

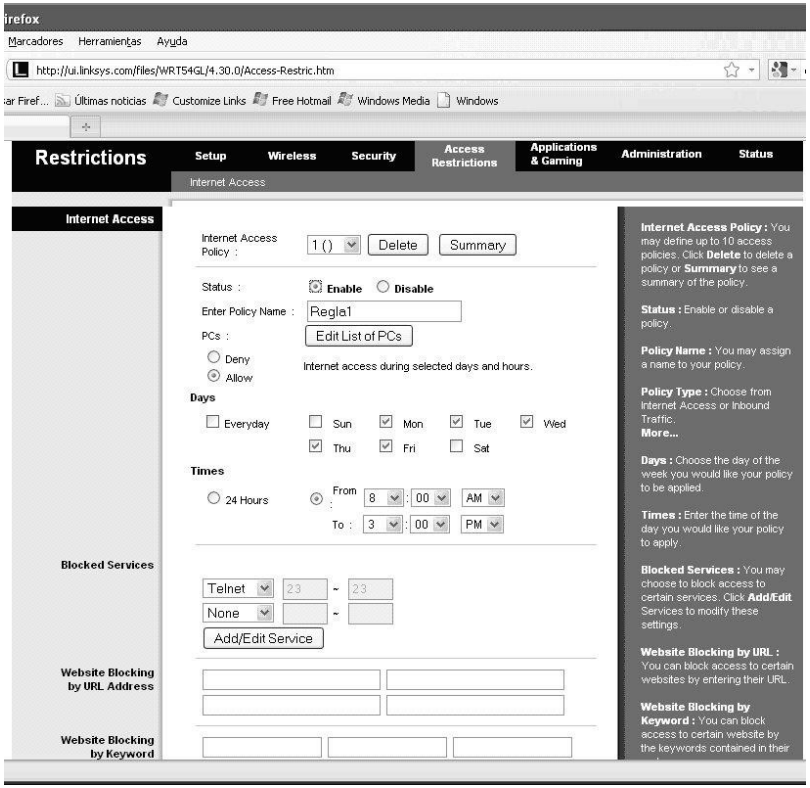
- **Cortafuegos de aplicación web (WAF)**: investiga el tráfico web entre el servidor web interno, publicado al exterior, e Internet para analizar los datos recibidos en el servidor web procedentes de la actividad del usuario y proteger al servidor de diferentes ataques de software:
  - SQL Injection (ejemplo)
  - Cross-Site Scripting (inclusión de código script malicioso en cliente web)
  - Inclusión de ficheros locales y remotos
  - Envenenamiento de cookies

modsecurity
Open Source Web Application Firewall

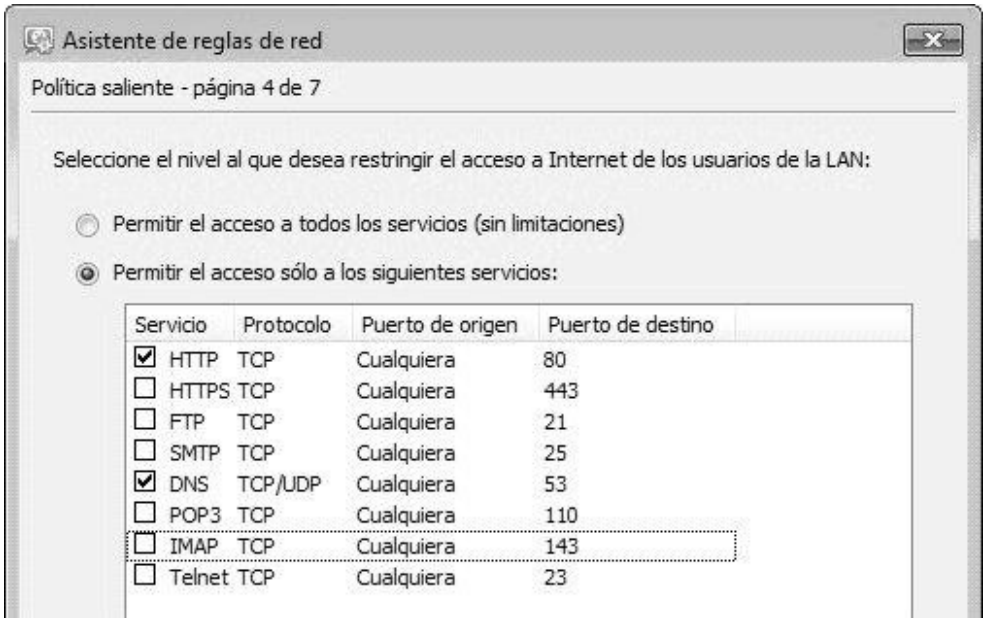


1.1. TIPOS DE CORTAFUEGOS (cont.)

Cortafuegos integrado en router



Cortafuegos de escritorio: Kerio Winroute Firewall



1.2. CONFIGURACIÓN DE CORTAFUEGOS

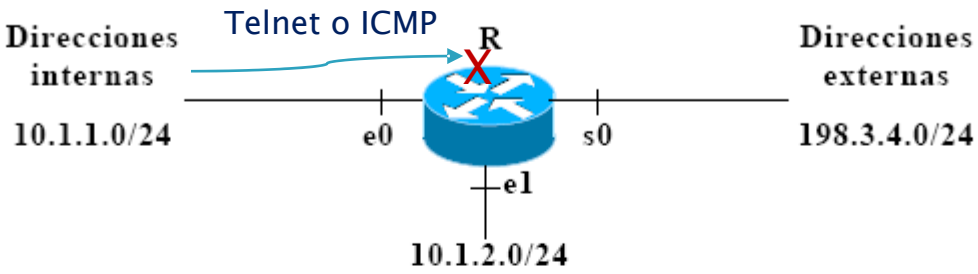
- Para el caso de los *routers* CISCO de gama media y alta, es posible configurar *listas de control de acceso* o **ACL**.

- **ACL**: listas de condiciones que se aplican al tráfico que viaja a través de una interfaz del *router*, y se crean según el protocolo, la dirección o el puerto a filtrar.

- Existen dos tipos de ACL:
  - **ACL estándar**, solo se especifica una dirección de origen.
  - **ACL extendida**, aparece el protocolo y una dirección de origen y de destino. Ofrecen un mayor control que las estándar.

1.2. CONFIGURACIÓN DE CORTAFUEGOS. Ejemplo Cisco

Queremos denegar en la interfaz s0 de salida cualquier paquete ICMP que provenga de la red 10.1.1.0/24 y el acceso a cualquier puerto telnet (puerto 23) por parte de un host de esa red.

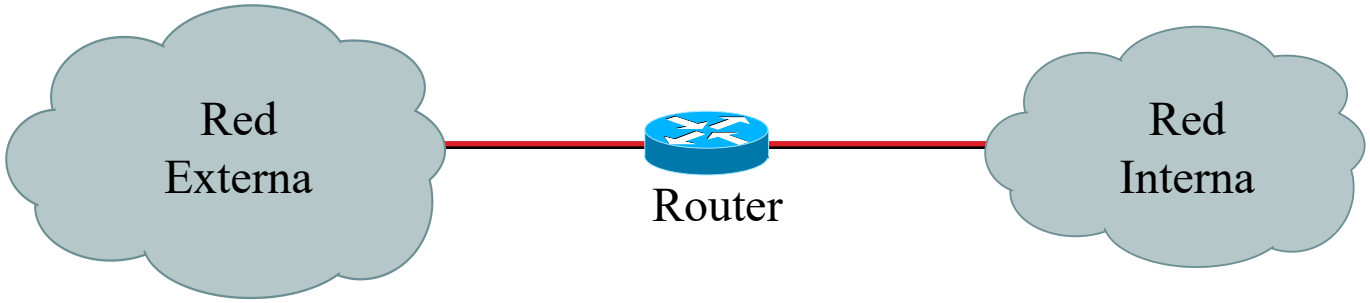



```
R# configure terminal
R(config)# access-list 101 deny icmp 10.1.1.0 0.0.0.255 any
R(config)# access-list 101 deny tcp 10.1.1.0 0.0.0.255 any eq 23
R(config)# access-list 101 permit any any
R(config)# interface s0
R(config-if)# ip access-group 101 out
R(config-if)# exit
R# show access-lists
```

Primero creamos la lista de acceso extendida 101, denegando el acceso de paquetes ICMP, segundo otra línea denegando el acceso a cualquier host con puerto 23, finalmente permitimos cualquier otro tipo de tráfico. A continuación aplicamos la lista de acceso a la interfaz de salida s0.

1.3. ARQUITECTURAS DE CORTAFUEGOS

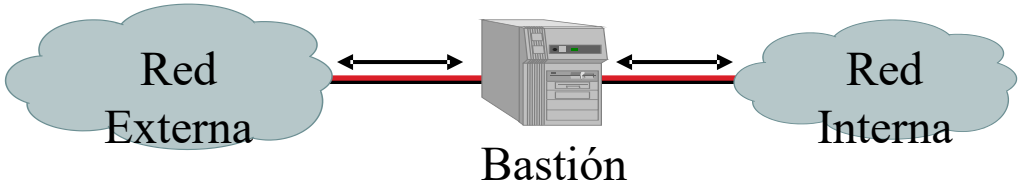
- **Screening router (router seleccionado)**: como frontera entre la red privada y la red pública se encuentra un ***router*** que realiza tareas de filtrado.



  - Es la configuración más simple y barata
  - Toda la seguridad de la red reside en un único punto.

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

- **Dual Homed-Host (host de base dual)**: como frontera se dispone ***un equipo servidor con 2 tarjetas de red*** que realizará tareas de filtrado. Esto permitirá una mayor flexibilidad en la configuración e instalación de aplicaciones de seguridad.



- En esta configuración, el **bastión puede filtrar hasta la capa de aplicación.**
- Son sistemas muy baratos y fáciles de implementar
- Soportan servicios mediante proxy
- El filtrado de paquetes, puede realizarse en *Linux* a través de "***iptables***" que son sentencias del tipo:

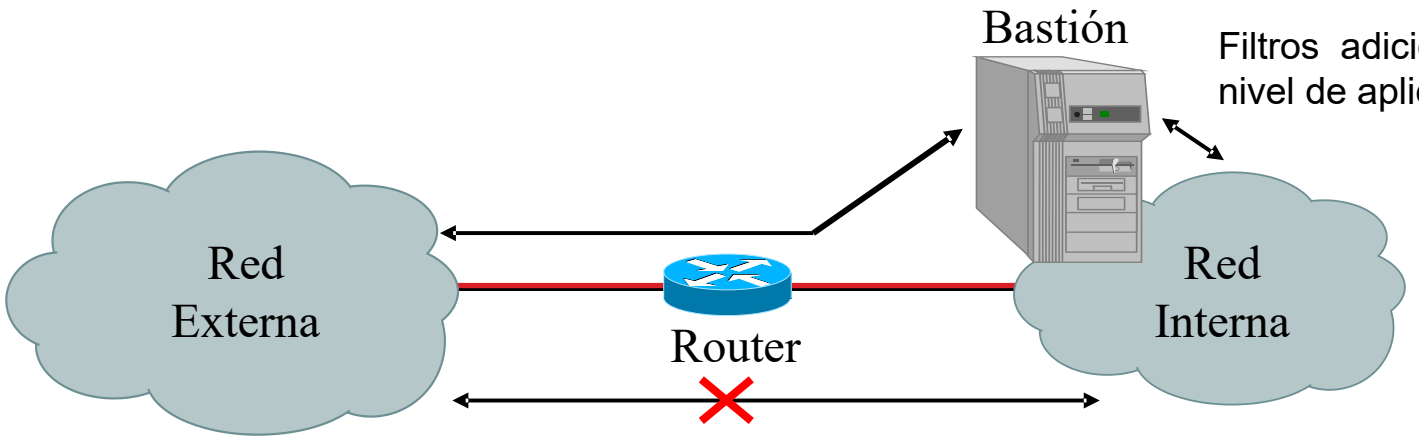
accept | deny *con declaración de puertos, direcciones IP, ...*

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

- En Windows Server con ***Forefront TMG 2010***.
- Recomendado para poco tráfico a Internet y no crítico y los datos no son valiosos.
- No realiza IP-Forwarding (los paquetes IP no se reenvían automáticamente).
- Requiere una aplicación que habilite la comunicación interior-exterior: Proxy.
  - Configurado para los servicios necesarios (ftp, http, etc.).
  - El proxy puede tener perfiles activados por usuario.
- Desde la zona segura el equipo se ve como uno más de la red.
- Desde el exterior el equipo es visto como uno más de Internet.

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

- **Screened Host (host bastión seleccionado)**: combina un ***router*** fronterizo exterior y un ***servidor proxy*** que filtrará y permitirá añadir reglas de filtrado en las aplicaciones más empleadas.



El *router* se sitúa entre la red local (interna) y la externa filtrando el tráfico de tal forma que sólo permite la entrada y salida de paquetes dirigidos al host bastión.

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

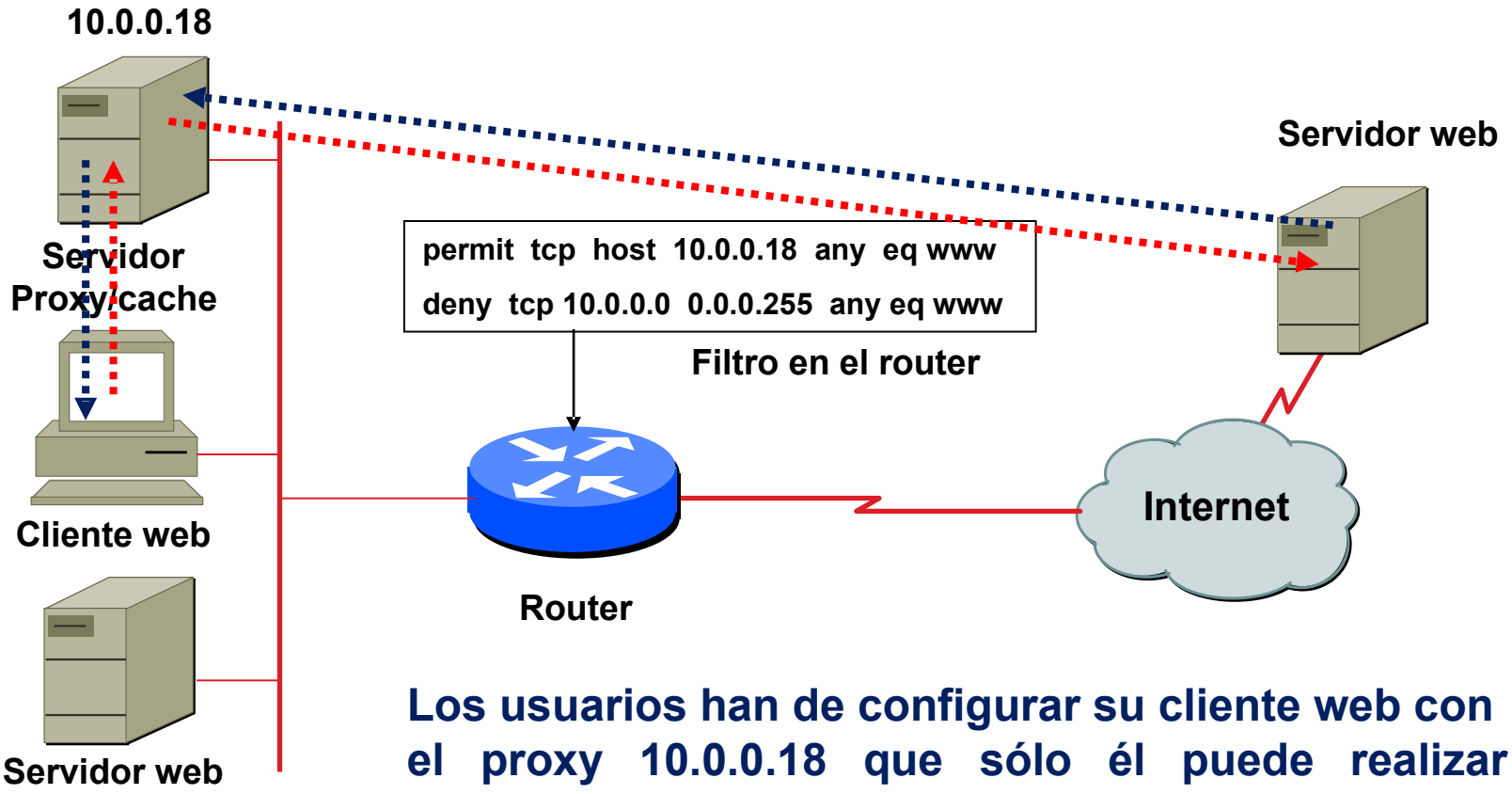
En dicho host, se sitúa una *aplicación proxy* que realiza filtros a *nivel de aplicación*, por lo tanto más flexibles, versátiles y complejos.

El router y el equipo bastión son colocados indistintamente en función de las necesidades.

Habitualmente el router es el más expuesto porque es el más sencillo de proteger.

SEGURIDAD PERIMETRAL

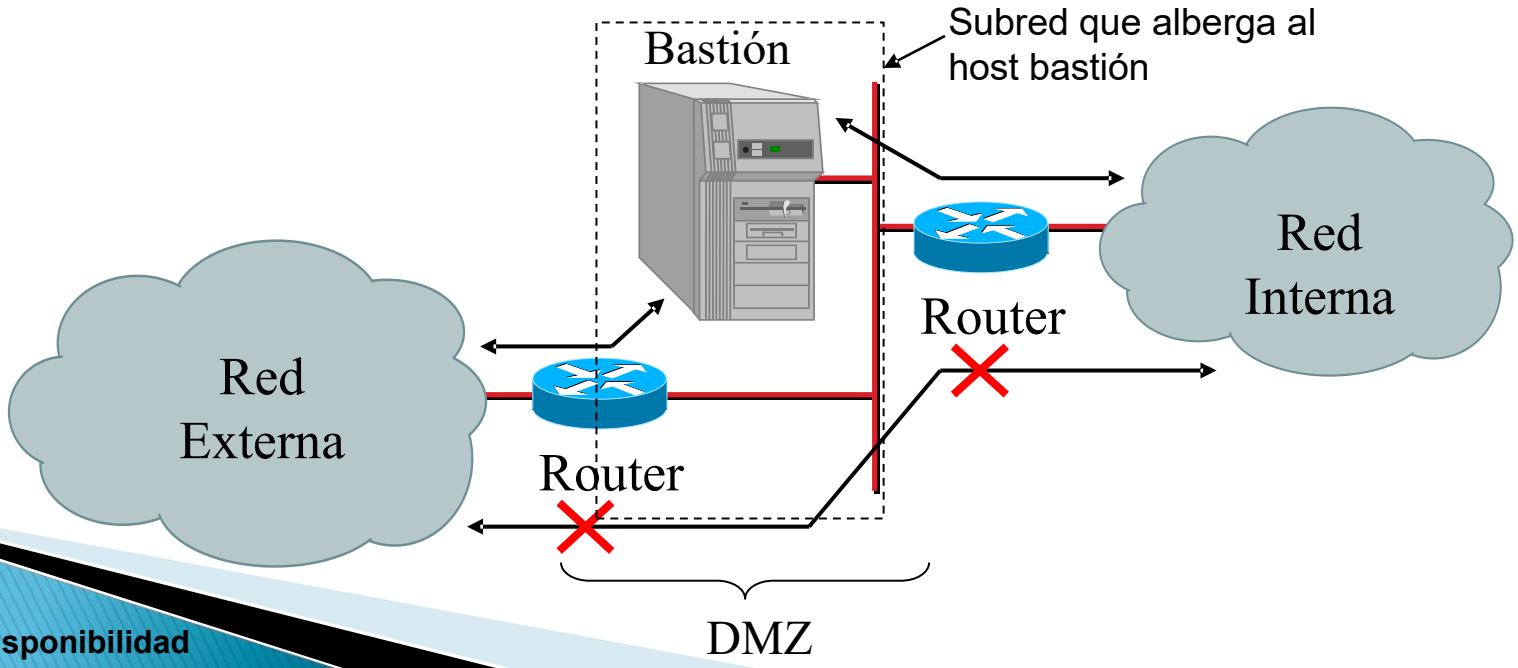
Host Bastión Seleccionado



Los usuarios han de configurar su cliente web con el proxy 10.0.0.18 que sólo él puede realizar conexiones al exterior por el puerto 80. Esto no afecta a los accesos a servidores web internos desde el exterior.

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

- **Screened-subnet (subred seleccionada):** consistente en implementar un perímetro con ***dos routers*** y ***un host bastión***. Es la **arquitectura más segura** y tiene las siguientes ventajas:
  - en ningún momento el exterior puede *saturar la red interna*, ya que están separadas
  - en ningún momento se puede *monitorizar* (sniffer) la red interna si es el caso de que el host bastión fuera saboteado, pues hay un segundo *router*.

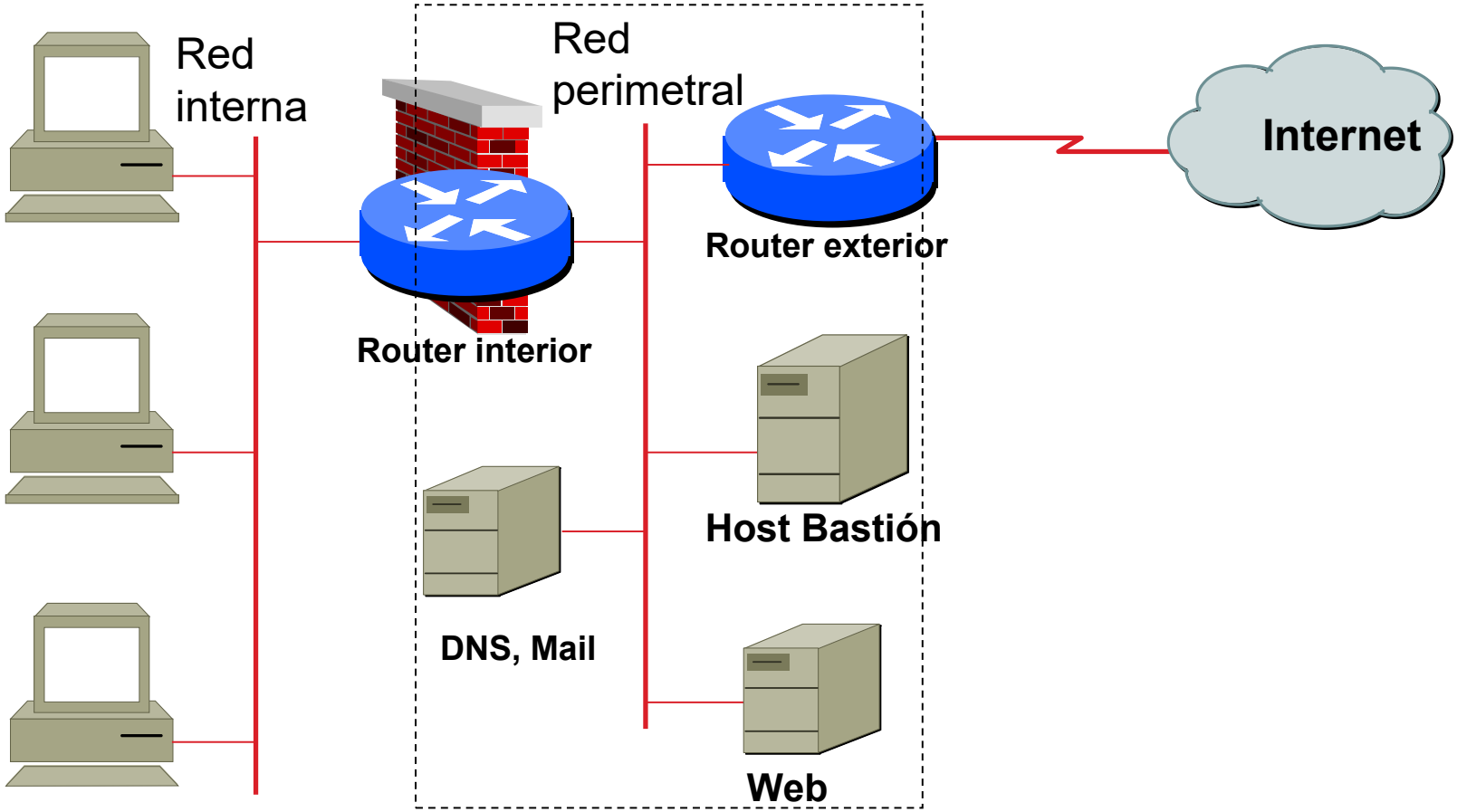


1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

- La **DMZ** (*DeMilitirized Zone*) o *red perimetral* se trata de una **red local** donde se ubican los **servidores** HTTP, DNS, FTP y otros que, en general, puedan ser de **carácter público**.
- **Está separada de la LAN y de la red externa o Internet**.
- Es la arquitectura **más utilizada** hoy día.
- El tráfico sospechoso se envía hacia el bastión si no puede pasar directamente.
- Soporta servicios mediante proxy (bastión) y filtrado de paquetes (*routers*).
- Es más complicada y cara de implementar que otras arquitecturas.
- Si el atacante entra en el *bastión*, todavía tiene un *router* por delante (no puede hacer *sniffing*). El *router* ya no es un único punto de fallo.

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

Subred Seleccionada

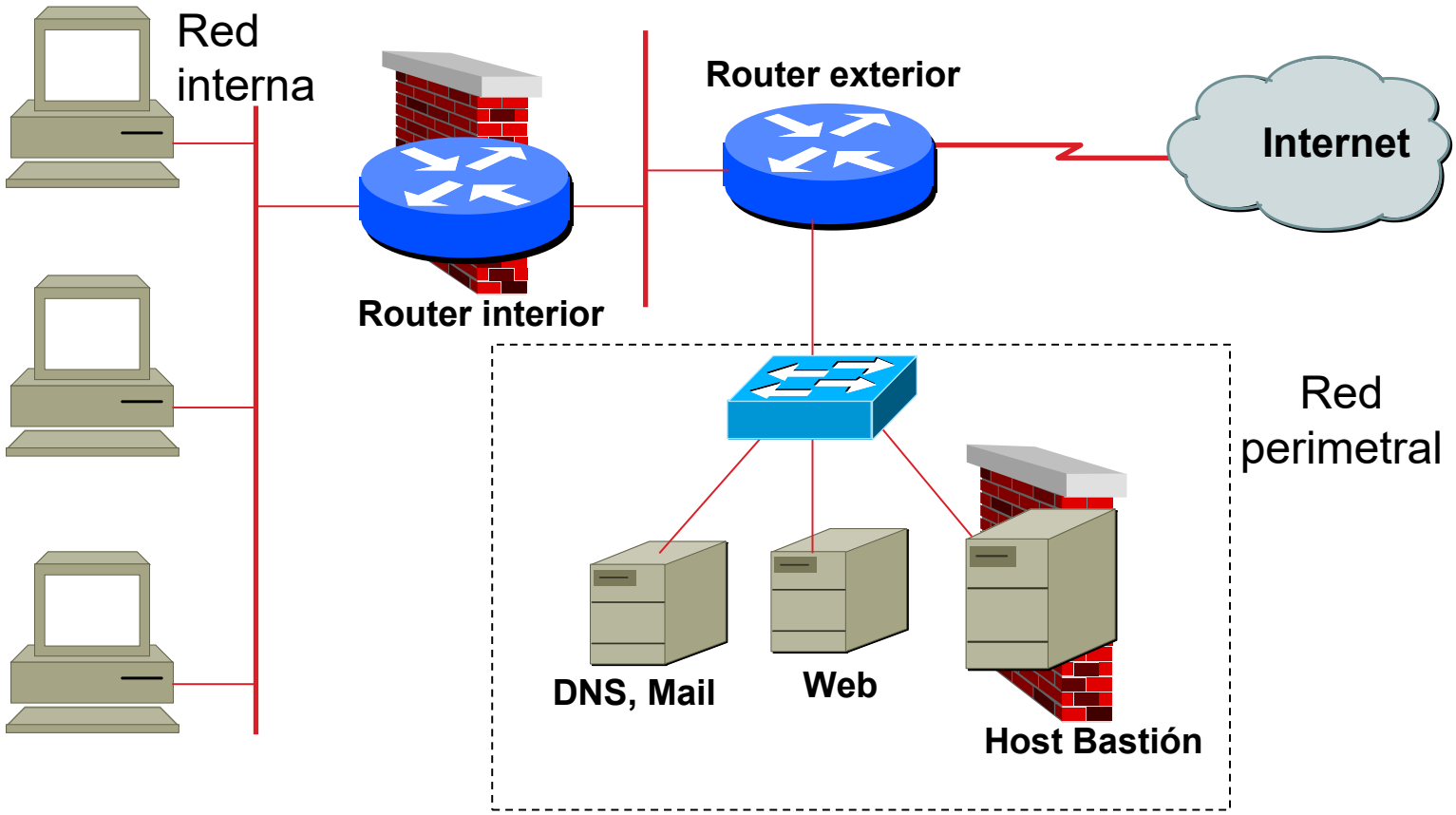


Zona desmilitarizada (DMZ) o
Free Trade Zone (FTZ)

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

Subred Seleccionada

Esquema de DMZ aún más lejos de la red interna.



Zona desmilitarizada (DMZ) o Free Trade Zone (FTZ)

1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

POLÍTICA DE SEGURIDAD

- Por lo general la **política de seguridad** para la DMZ es la siguiente:
  - El tráfico de la red externa a la DMZ está autorizado y a la **red interna** está **prohibido**.
  - El tráfico de la red interna a la DMZ está autorizado y a la **red externa** está **filtrado**.
  - Desde la DMZ no se permiten conexiones a la red interna.



1.3. ARQUITECTURAS DE CORTAFUEGOS (cont.)

POLÍTICA DE SEGURIDAD (cont.)

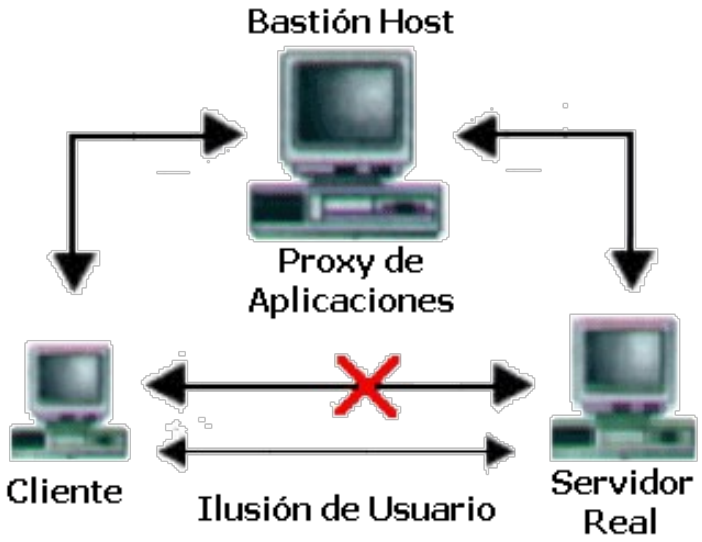
- Normalmente el host DMZ está separado de Internet a través de un *router* y un *cortafuegos*, o se encuentran integrados.
- Es aconsejable que en el cortafuegos se abran al exterior únicamente los **puertos de los servicios** que se pretende ofrecer con los servidores disponibles en la DMZ.
- No siempre podemos tener una configuración basada en perímetro exterior-interior.
- Es posible establecer varios perímetros de seguridad en según los recursos que tengamos.

2. PROXY

- Un servidor **proxy** o representante es una *aplicación o sistema que gestiona las conexiones de red, sirviendo de* ***intermediario*** *entre las peticiones de servicios que requieren los clientes*, como http, ftp, irc, ssh, etc., creando así una ***memoria caché*** de dichas peticiones y respuestas por parte de los servidores externos.

El Proxy, instalado sobre el Host Bastión, actúa de intermediario entre el cliente y el servidor real de la aplicación, siendo transparente a ambas partes.

Cuando un usuario desea un servicio, lo hace a través del Proxy. Este realiza la petición al servidor real y devuelve los resultados al cliente. Su función es la de analizar el tráfico de red en busca de contenido que viole la seguridad de la misma.



2. PROXY

- Otra finalidad de este tipo de servidores es poder ***servir más rápidamente*** a sus usuarios en ***conexiones siguientes*** que hayan sido solicitadas, sin tener que acceder remotamente de nuevo a los servidores externos. Es decir, realiza funciones de ***caché*** web.
- Añaden **funciones** de control y autenticación de usuarios, y reglas de filtrado de los contenidos solicitados, así como registro de Logs (por ejemplo, registrar conexiones).

- Ventajas
  - Mejora de velocidad de respuesta a peticiones
    - Si varios clientes van a pedir el mismo recurso, el proxy puede hacer **caché**, es decir, guardar la respuesta de una petición para darla directamente cuando otro cliente la pida.
    - Así el cliente no tiene que volver a contactar con el destino.
  - Proporciona seguridad en acceso a contenidos.

2.1. Tipos, características y funciones principales

- Dependiendo del tipo de tráfico que circulará por una red necesitaremos un proxy que cumpla las necesidades del tráfico:
  - Ya sea para *acelerar la descarga de contenidos* con el objeto de no sobrecargar la salida a Internet.
  - Ya sea para *autenticación de usuarios*.

- En función de estas características se pueden clasificar los *proxies* de la siguiente manera:

  - **Proxy caché Web:** aplicación específica de acceso a la web. Mantiene copias locales (caché) de los archivos más solicitados, los cuales son compartidos todos los equipos de la red, con la consiguiente mejora en los tiempos de acceso para consultas coincidentes.

2.1. Tipos, características y funciones principales

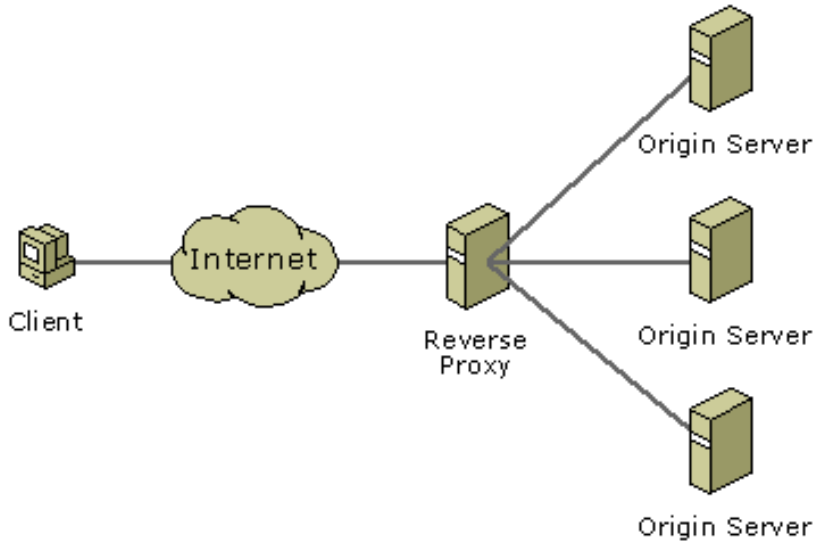
- **Proxy NAT**: integración de los servicios de traducción de direcciones de red y proxy.

- **Proxy transparente**: normalmente, un proxy Web o NAT no es transparente a la aplicación cliente. Debe ser configurado para usar el proxy, manualmente. *Un proxy transparente combina un servidor proxy con NAT de manera que las conexiones al puerto 80 son redirigidas hacia el puerto del servicio proxy*. Es el tipo de proxy que utilizan los ISP.

- **Proxy anónimo**: permite aumentar la **privacidad** y el anonimato de los clientes proxy mediante una activa eliminación de características identificativas (dirección IP del cliente, cabeceras *From* y *Referer*, *cookies*, identificadores de sesión,...).

2.1. Tipos, características y funciones principales

- **Proxy inverso:** servidor proxy instalado en una red con varios servidores web internos, sirviendo de intermediario a las peticiones externas, suponiendo una capa de seguridad previa, gestión y **distribución de carga** de las distintas peticiones externas, gestión de SSL o como caché de contenidos estáticos.



2.2. Configuración de un proxy

- GNU/Linux: Proxy por excelencia es **Squid** y *Dansguardians*.
- Squid: Archivo de configuración: */etc/squid3/squid.conf*.
  - Puerto de escucha: http_port **3128**
  - Dirección de la caché y el tamaño:
    - cache_dir *ufs /var/spool/squid3 2000 16 256*
    - cache_mem 32 MB
    - maximum_object_size_in_memory 256 MB
  - Direcciones logs de acceso al proxy y de caché
    - access_log */var/log/squid/access.log*
    - cache_log */var/log/squid/cache.log*



2.2. Configuración de un proxy (cont.)

- Añadir usuarios a /etc/squid3/claves:
  - *htpasswd -c /etc/squid3/claves ana*

Creación de un usuario denominado “ana”

- Autenticación básica de usuarios (similar a la del servicio HTTP):
  - *auth_param basic program /usr/lib/squid3/ncsa_auth /etc/squid3/claves*
  - *acl passwd proxy_auth REQUIRED*

Registro de usuarios en el servidor Proxy

Y ACL para requerir autenticación en el servidor proxy.

2.2. Configuración de un proxy (cont.)

- Filtrado (definición de ACLs y denegación/aceptación):
  - *acl nopermitidas url_regex "/etc/squid/nopermitidas"*
  - *acl nowebs dstdomain "/etc/squid/nowebs"*
  - *http_access deny nopermitidas*
  - *http_access deny nowebs*

Denegar acceso a un conjunto de URL´s y de dominios registrados en sendos ficheros.

- Proxy **transparente**: redirección peticiones puerto 80 al 3128 (proxy-squid):
  - *iptables -t nat -A PREROUTING -i eth0 -p tcp --dport 80 -j REDIRECT --to-port 3128*

Obligar a pasar las peticiones web por el proxy.

- Otras funciones: Añadir *blacklist* descargada o gestión web mediante módulo squid en *webmin*.

3. Otras posibles arquitecturas de seguridad perimetral

- Es posible combinar los diferentes tipos de firewall para obtener una arquitectura en función de nuestras necesidades.
- Cuanto más segura más difícil de configurar.
- A mayor número de equipos mayor coste.
- Algunas organizaciones implementan un host bastión por servicio (o un host con proxies para diferentes servicios).
- División de red interna en subredes.
- Una arquitectura demasiado compleja o sencilla puede dar lugar a vulnerabilidades.

DIRECCIONES DE INTERÉS

- **Completa información práctica sobre iptables:**
  - http://www.kriptopolis.org/iptables-0
- **Listado de cortafuegos personales:**
  - http://www.infospyware.com/cortafuegos/
- **Configuraciones prácticas de cortafuegos:**
  - http://es.tldp.org/Manuales-LuCAS/doc-iptables-firewall/doc-iptables-firewall.pdf
- **Configuraciones de enrutamiento, Proxy y cortafuegos para GNU/Linux:**
  - http://www.ite.educacion.es/formacion/materiales/85/cd/linux/m6/cortafuegos_iptables.html

SEGURIDAD PERIMETRAL

SOFTWARE–SIMULADORES

- **Simuladores de configuración de dispositivos TP-LINK**
  - **https://www.tp-link.com/es/support/emulator/**
- **Simuladores de configuración de dispositivos LINKSYS**
  - **https://ui.linksys.com/**
- **Simuladores de configuración de dispositivos D-LINK**
  - **https://tools.dlink.com/intro/emulator/**

SEGURIDAD PERIMETRAL

SOFTWARE

- **Iptables: cortafuegos de sistemas GNU/Linux.**
  - **http://www.netfilter.org/**
- **Squid: servidor Proxy, entornos GNU/Linux.**
  - **http://www.squid-cache.org/**

SEGURIDAD PERIMETRAL

SOFTWARE

- **E2guardian web filtering.**
  - **http://e2guardian.org/cms/index.php**
- **WinGate: software Proxy Server para sistemas Windows.**
  - **http://www.wingate.com/**
- **Webmin: gestión integral de servicios como Proxy en sistemas operativos GNU/Linux, desde entorno web.**
  - **http://www.webmin.com/**
- **Kerio Winroute firewall: gestión integral bajo Windows, con funciones de enrutamiento y cortafuegos.**
  - **http://www.kerio.com/**
- **Zone Alarm: Software cortafuegos - firewall**
  - **https://www.zonealarm.com/es**